

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

ASSESSMENT TOOL 2 – INCIDENT ANALYSIS (ROOT CAUSE & RISK)

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Incident Investigation, Root Cause Analysis and Risk Assessment.		
Student Name:	Syed Saniya Iqbal	Reg. No.:	192465043
Section / Batch:	CSE-Cybersecurity	Date:	27/08/2026

Instructions to Students

- Review the given security incident scenario, evidence, logs and indicators carefully before beginning the analysis.
- Identify the incident sequence, affected assets, relevant indicators and supporting evidence without making unsupported assumptions.
- Determine the root cause by linking observed events, vulnerabilities and contributing conditions in a logical sequence.
- Assess identified risks based on likelihood, severity and potential technical or operational impact.
- Present investigation findings, root-cause reasoning and risk assessment clearly with appropriate technical justification.

Question Type	Focus Area	Questions	Marks
INCIDENT ANALYSIS	Investigation & Risk	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

1. Incident Overview

Scenario: A social-media security dashboard shows a sudden increase in account-takeover alerts along with a high volume of automated login attempts. This pattern is consistent with credential-stuffing, password-spraying, bot-driven authentication abuse, or a combination of these techniques.

Primary security concern: Attackers may be using stolen usernames and passwords, automated tools, proxy networks, or compromised devices to gain unauthorized access to user accounts.

2. Incident Analysis

- **Observed indicators:** Rapid growth in failed login attempts, repeated attempts against many accounts, unusual IP/ASN or geographic patterns, abnormal device fingerprints, login bursts at machine-like intervals, and successful logins followed by suspicious account activity.
- **Likely attack methods:** Credential stuffing using breached credentials; password spraying using a small set of common passwords; bot automation; proxy/IP rotation; and session or credential abuse after a successful login.
- **Potential impact:** Account compromise, identity impersonation, privacy breaches, unauthorized messages or posts, financial or advertising abuse, reputation damage, and lateral compromise of connected services.
- **Root cause hypothesis:** The most probable root causes are password reuse by users, exposure of credentials in previous breaches, insufficient authentication controls, lack of effective bot detection, and inadequate rate limiting on login endpoints.

3. Risk Assessment

Risk	Likelihood	Impact	Priority
Credential-stuffing/account takeover	High	Critical	Immediate
Automated bot login abuse	High	High	Immediate
Password spraying	Medium–High	High	High
User/session abuse after compromise	Medium	Critical	High
Service degradation from login traffic	Medium	Medium–High	High

4. Incident Response Plan

Phase 1 – Preparation

Maintain centralized authentication logs, user/device/IP telemetry, alert thresholds, incident contacts, backup procedures, and tested recovery playbooks. Ensure security teams can revoke sessions and force password resets.

Phase 2 – Detection and Analysis

Correlate failed and successful logins by account, IP, device, ASN, location, user agent, and time. Identify bursts, distributed attempts, impossible-travel patterns, repeated device fingerprints, and accounts with multiple failed attempts followed by a successful login. Determine the attack scope and affected accounts.

Phase 3 – Containment

Immediately rate-limit suspicious sources, challenge or block automated requests, step up authentication for high-risk logins, revoke active sessions for confirmed compromised accounts, and temporarily lock accounts showing strong takeover indicators. Preserve logs and evidence before making destructive changes.

Phase 4 – Eradication

Remove attacker persistence such as unauthorized sessions, recovery-email changes, malicious applications, or altered security settings. Force password resets where compromise is suspected and invalidate stolen sessions or tokens. Block confirmed malicious infrastructure.

Phase 5 – Recovery

Restore affected accounts securely, require MFA re-verification, monitor recovered accounts closely, and gradually relax temporary controls only after attack indicators return to normal. Communicate clearly with affected users.

Phase 6 – Lessons Learned

Review the timeline, detection quality, false positives, response time, affected accounts, and control effectiveness. Update rate limits, bot models, risk rules, MFA coverage, dashboards, and incident playbooks based on findings.

5. Mitigation Strategies and Justification

Control	How It Works	Why It Is Needed	Expected Benefit
Multi-Factor Authentication (MFA)	Requires a second factor such as an authenticator-app code, passkey, or hardware security key in addition to a password.	Stolen passwords alone should not be enough to access an account.	Strongly reduces successful account takeover from credential theft.
Rate Limiting	Restricts the number and frequency of login attempts per account, IP, device, or risk bucket.	Automated attacks depend on making large numbers of authentication attempts quickly.	Slows brute force and credential stuffing and reduces authentication-service load.
Risk-Based Authentication (RBA)	Calculates login risk using device, location, IP reputation, behavior, velocity, and historical patterns.	Legitimate users and attackers do not always behave the same way.	Applies friction selectively: normal users get easier access while risky logins receive challenges or blocks.
Bot Detection	Uses behavioral signals, device/browser characteristics, request patterns, reputation data, and bot challenges to distinguish automation	The dashboard indicates automated login activity, so stopping automation at the edge is essential.	Reduces malicious login volume and prevents attackers from scaling attempts cheaply.

	from humans.		
--	--------------	--	--

6. Recommended Technical Controls

- Enable MFA by default for administrators and progressively enforce it for all users, prioritizing high-risk accounts.
- Use strong password policies and screen new passwords against known compromised-password lists.
- Apply adaptive rate limits at multiple levels: IP, account, device, ASN/network, and global authentication service.
- Use bot-management controls at the CDN/WAF or authentication gateway so malicious traffic can be filtered before reaching core services.
- Implement risk scoring and step-up authentication rather than relying only on a static allow/block decision.
- Detect impossible travel, unusual device changes, anomalous login velocity, and sudden changes to recovery settings.
- Revoke sessions and refresh tokens after confirmed compromise or major credential changes.
- Alert on successful logins that occur immediately after abnormal failure bursts.
- Maintain immutable or access-controlled authentication logs for forensic investigation.
- Monitor post-login actions such as bulk messaging, password/recovery changes, profile changes, and unusual API activity.

7. Incident Handling Workflow

1. Dashboard alert triggered
2. Correlate login, device, IP and behavior evidence
3. Classify severity and identify affected accounts
4. Apply rate limiting and bot controls
5. Trigger MFA / risk-based challenge for suspicious users
6. Contain confirmed compromised accounts and revoke sessions
7. Reset credentials and remove attacker persistence
8. Recover accounts and notify affected users
9. Monitor for recurrence
10. Conduct post-incident review and improve controls

8. Evidence to Collect

- Authentication logs: timestamps, success/failure, username/account identifier, source IP and response codes.
- Device and browser fingerprints, user-agent information, session identifiers, and authentication method used.
- IP/ASN reputation and geographic information, including proxy/VPN/TOR indicators where legally and operationally appropriate.
- Rate-limit, WAF, CDN, bot-management, and CAPTCHA/challenge events.
- Password-reset, MFA enrollment, recovery-email/phone changes, and session/token revocation events.
- Post-login activity that may indicate abuse, including unauthorized posts, messages, profile edits, or API calls.

9. Success Metrics

- Reduction in successful account-takeover events.

- Reduction in automated login attempts reaching the authentication service.
- Percentage of active users protected by MFA.
- Mean time to detect (MTTD) and mean time to contain (MTTC).
- False-positive rate for risk-based authentication challenges.
- Percentage of confirmed compromised accounts with sessions revoked within the response target.
- Availability and latency of the authentication service during attack periods.

10. Conclusion

The increase in account-takeover alerts combined with automated login attempts indicates a high-priority authentication security incident. The response should combine rapid detection and containment with stronger preventive controls. MFA is the key defense against stolen passwords, rate limiting reduces the speed and scale of automated attacks, risk-based authentication adds context-aware protection, and bot detection prevents attackers from repeatedly testing credentials at scale. Together, these controls provide layered defense and improve both security and service resilience.

11. Final Recommended Response

Immediate: Enable aggressive but carefully tuned rate limits, activate bot detection, identify high-risk accounts, step up MFA, revoke suspicious sessions, and preserve evidence.

Short term: Expand MFA coverage, deploy risk-based authentication, improve compromised-password detection, and correlate login telemetry across accounts, devices, and networks.

Long term: Adopt continuous authentication monitoring, regularly test incident-response procedures, tune behavioral models, and conduct post-incident reviews to reduce recurrence.